L'OPTION

API keys, test environments and production readiness

Everything that must be configured, tested and approved before the app can be released in Morocco

Item	Value
As of	2026-11-05
Repository / branch	taha222222/loption-mobile, latest branch claude/v1-gps-live-map (commit 6d16c8e); nothing merged into main
Hosted project	Supabase loption-mobile (ref teppcfnpkoxkudajnvad, region eu-west-1 Ireland)
Sources	docs/v1/REMAINING_SETUP_AND_RELEASE_TASKS.md, AUTH_PROVIDER_SETUP.md, PRIVACY_AND_STORE_RELEASE.md, STANDALONE_TRACKING.md, DEVICE_TEST_PROCEDURES.md, DECISIONS.md, .env.example, supabase/server-secrets.env.example

This document lists the NAMES of the keys, where to create them and where to store them. It contains no key, password or secret value, and none should ever be written into it, into git, into an EXPO_PUBLIC_ variable or into a chat. Legal points are a checklist for a Moroccan lawyer and accountant, not legal advice.

1. Where each kind of secret is allowed to live

The app bundle is public: anyone can read it. Only two public values go into the app; every other credential stays on a server or in the build service.

Place	What may be stored there	Never store there
App .env (EXPO_PUBLIC_*)	EXPO_PUBLIC_SUPABASE_URL and EXPO_PUBLIC_SUPABASE_ANON_KEY only (public by design, protected by RLS)	Service-role key, database password, OAuth secrets, Apple .p8, Resend key, cron secret, Maps key
Supabase Dashboard	Auth providers (Google, Apple), SMTP (Resend), Edge Function secrets, Vault secret for the cron job	Anything copied back into the app
EAS (Expo) project	Build environment variables (GOOGLE_MAPS_ANDROID_API_KEY), signing credentials, APNs key, FCM V1 credentials, store submit credentials	Values in eas.json or in git
Owner password manager	Database password, Apple .p8 files, Google Play service-account JSON, Expo access token, backups of all of the above	Shared documents, e-mail, chat
Git repository	Only names and empty templates (.env.example, server-secrets.env.example)	Any real value (.env, *.env, *.p8 are git-ignored)

2. Inventory of keys and credentials

Status reflects the repository on 2026-11-05. "Blocks" says what cannot be released or tested without it.

#	Name	Used for	Where to create	Where to store	Type	Status	Blocks
1	EXPO_PUBLIC_SUPABASE_URL	App to Supabase	Supabase Dashboard > Project Settings > API	App .env / EAS env (public)	Public	Configured (dev); production project still to decide (B6)	Everything
2	EXPO_PUBLIC_SUPABASE_ANON_KEY	App to Supabase (RLS-protected)	Supabase Dashboard > Project Settings > API (anon / publishable)	App .env / EAS env (public)	Public	Configured (dev)	Everything
3	SUPABASE_SERVICE_ROLE_KEY	Edge Function dispatch-notifications only	Provided automatically to Edge Functions	Supabase only	SECRET	Not needed in the app (rejected by src/config/env.ts)	Push dispatcher
4	Database password	Supabase CLI, migrations by the owner	Supabase Dashboard > Database	Password manager	SECRET	Owner holds it	Owner-run migrations
5	Google OAuth client ID + secret	Sign in with Google	Google Cloud Console > APIs & Services > Credentials (Web application, redirect https://<ref>.supabase.co/auth/v1/callback)	Supabase > Authentication > Providers > Google	SECRET (secret part)	Missing (A1)	Google sign-in; App Store 4.8 then also needs Apple
6	Apple Team ID, Services ID, Key ID, Sign in with Apple key (.p8), client-secret JWT	Sign in with Apple (native iOS + web/Android)	Apple Developer > Certificates, Identifiers & Profiles (paid membership)	Supabase > Providers > Apple; .p8 in password manager	SECRET (.p8, JWT)	Missing (A2); JWT expires at most every 6 months	Apple sign-in, iOS release
7	Resend API key + verified sending domain (SPF/DKIM)	Verification e-mails (Supabase Auth SMTP: smtp.resend.com:465, user resend)	resend.com > Domains, API Keys	Supabase > Authentication > SMTP Settings	SECRET	Missing (A3)	E-mail sign-up in production
8	NOTIFICATIONS_CRON_SECRET	Protects the push dispatcher (x-cron-secret header)	Random value chosen by the owner	Supabase Edge Function secrets + Vault (cron job)	SECRET	Not configured; function not deployed	Reminder notifications
9	EXPO_ACCESS_TOKEN (optional)	Expo enhanced push security	expo.dev > Account > Access tokens	Supabase Edge Function secrets	SECRET	Optional, not configured	Only if enhanced security is enabled
10	APNs key (.p8)	iOS push delivery	Apple Developer > Keys (Apple Push Notifications)	EAS credentials	SECRET	Missing (E3)	Push on iPhone
11	FCM V1 service-account JSON	Android push delivery	Firebase Console > Project settings > Service accounts	EAS credentials	SECRET	Missing (E3)	Push on Android
12	GOOGLE_MAPS_ANDROID_API_KEY	Map tiles on the Android live workout map	Google Cloud > enable Maps SDK for Android > Credentials; restrict to com.loption.app + EAS SHA-1 and that API only	EAS environment variable, visibility sensitive (read by app.config.js)	Restricted key	Missing (DECISIONS #27); Android shows route without map	Android map tiles only (iPhone uses Apple Maps, no key)

#	Name	Used for	Where to create	Where to store	Type	Status	Blocks
13	Expo account / EXPO_TOKEN	EAS builds and submit (also from Windows, CI)	expo.dev > Account > Access tokens	Password manager / CI secret	SECRET	Not available to development	Every native build, iOS compile
14	Android upload keystore	Signs Play Store builds	Generated and kept by EAS (recommended)	EAS credentials (+ backup)	SECRET	Not created yet	Play release
15	iOS distribution certificate + provisioning profiles; App ID com.loption.app with Sign in with Apple, HealthKit (if kept)	Signs iOS builds	Apple Developer (EAS can create them)	EAS credentials	SECRET	Not created yet	iOS release, TestFlight
16	App Store Connect API key (.p8, Issuer ID, Key ID)	eas submit to TestFlight / App Store	App Store Connect > Users and Access > Integrations	EAS / password manager	SECRET	Missing	Automated iOS submission
17	Google Play service-account JSON	eas submit to Play	Play Console > Setup > API access	EAS / password manager	SECRET	Missing	Automated Play submission

Not keys but required declarations: Apple HealthKit capability (if Apple Health stays), Google Play Health Connect declaration (if Health Connect stays), Play foreground-service (location) declaration with demo video, App Store background-location justification (DECISIONS #20, PRIVACY_AND_STORE_RELEASE.md).

3. Recommended configuration order

Step	Action	Who	Checklist
1	Decide the production Supabase project (or keep loption-mobile) and record its URL and anon key for production builds	Owner	B6
2	Create the Expo account access and EAS project credentials (Android keystore, iOS certificates) - unblocks the first iOS compile	Owner	E4, K7
3	Resend: verify the sending domain (SPF/DKIM), create the API key, configure Supabase SMTP, French templates, "Confirm email" ON	Owner	A3
4	Google OAuth client + Supabase Google provider; redirect allow-list loption://auth-callback	Owner	A1
5	Apple: App ID capabilities, Services ID, .p8 key, Supabase Apple provider, private-relay sender registration	Owner	A2
6	Google Maps Android key (restricted) as EAS variable GOOGLE_MAPS_ANDROID_API_KEY	Owner	M22, #27
7	Push: APNs key and FCM V1 JSON in EAS; NOTIFICATIONS_CRON_SECRET in Supabase secrets and Vault; deploy dispatch-notifications only after approval	Owner	E3, L
8	Build development clients: eas build -p ios / -p android --profile development; run the device procedures	Owner + Dev	E4, M18
9	Store credentials for submission (App Store Connect API key, Play service account) once listings exist	Owner	K10

Verification without exposing a key: Supabase GET /auth/v1/settings (anon key) shows which providers are enabled; the app then shows the Google / Apple buttons instead of "Pas encore configuré". A key is never printed in logs, screenshots or evidence entries.

4. Test environments and what each one needs

The local end-to-end harness needs **no API key at all**: it starts disposable Supabase services in Docker and an SMTP sink. Real-provider and device tests need the credentials of section 2 on a staging project.

Level	Command	Requires	Covers	Does not cover	Status
Unit + type + lint	npm ci; npm run check (tsc + expo lint + jest)	Node + npm (lockfile)	App logic with Supabase mocked: 309 tests	Real services, devices	Done: 309/309 pass; lint 45 pre-existing errors
SQL / RLS harnesses	bash supabase/tests/run_phase1c.sh, run_v1_onboarding_offer.sh, run_v1_nutrition.sh, run_v1_activity.sh, run_v1_standalone.sh, run_v1_account_deletion.sh, run_single_request_apply.sh	Docker daemon, psql, python3	Migrations, RLS, grants, refusals, concurrency, rollback, monitor	Hosted Auth settings, Storage/CDN	Done: all pass (E-30)
Local end-to-end	bash supabase/tests/e2e/run_app_e2e.sh	Docker, psql, node with Playwright Chromium, python3, npx. No keys	Web build against real local Postgres 17.6 + GoTrue + PostgREST: sign-up with e-mail confirmation (SMTP sink), onboarding, nutrition, tracking, workouts, account-deletion migration	Google/Apple (only their "not configured" path), real e-mail, native permissions, real push	Done: 76 checks pass (E-31)
Staging end-to-end with real providers	Same journeys by hand or scripted against a staging project	Staging project + keys 5, 6, 7 (+ 10, 11, 8 for push)	Real Google/Apple sign-in, real e-mail, real push, hosted RLS/Storage	-	Not started (A1.5, A2.6, A3.5, C4, K6)
Native builds	eas build -p android|ios --profile development|production	Expo token, signing credentials; Maps key for Android map	Real binaries; first Swift compile	-	Android release built locally (debug key); iOS never compiled
Physical devices	docs/v1/DEVICE_TEST_PROCEDURES.md (I1-I11, D1-D12, B1-B9, G1-G17)	iPhone (iOS 17+), Android 10+ with and without step sensor, dev builds	Sensors, background GPS, notifications, permissions, battery	-	Not started: nothing verified on a device

5. Production readiness - technical and store requirements

The app is production-ready only when every row below is done or waived in writing by the owner (checklist K13, K14).

Area	Requirement	Status today
Server pricing and checkout	Approved delivery fee, service fee, TVA, minimum order; trusted server-side order creation (one transaction, idempotent, cash on delivery only); checkout disabled until then	Not started: pricing not approved (H1-H11)
Database security	Phase 1C independent review; staging rehearsal of migrations and rollback; meal-images mitigation; hosted advisors clean or accepted	Partly: migrations applied on loption-mobile; review and M2 open (J1-J12)
Auth providers	Google, Apple and e-mail work on real devices; account linking policy; minimum age	Missing credentials and decisions (A, C5, C7)
Account deletion	In-app deletion (Apple 5.1.1(v), Google Play) + web deletion link for Play	Built and tested locally; migration not applied on hosted (DECISIONS #23); web page missing
Native builds	EAS development and production builds for iOS and Android; release build without local configuration	Android built locally; iOS never compiled; no EAS build
Device verification	All device procedures passed with evidence (steps, GPS, notifications, permissions, offline)	Not started
Calorie engine	Owner approval of BMR x 1.1, 0.5 kcal/kg/km and MET values; estimates labelled, not medical advice	Pending (DECISIONS #16, #19)
Apple App Store	App Privacy labels; purpose strings; background-location justification; HealthKit capability if kept; Sign in with Apple if Google is offered (4.8); privacy policy URL; privacy manifest report	Drafted only (PRIVACY_AND_STORE_RELEASE.md)
Google Play	Data safety form; foreground-service (location) declaration + demo video; Health Connect declaration if kept; account deletion URL; target API level current (app targets SDK 36)	Drafted only
Operations	Production Supabase backups, monitoring, support contact, incident owner, release approval in writing	Not started (K11, K14)

6. Government and legal requirements in Morocco (for legal review)

Checklist to review with a Moroccan lawyer and accountant before launch. It names the main texts to check; it is not legal advice and does not replace confirmation with the authorities (CNDP, ONSSA, DGI, commune).

Topic	Rule / authority to check	What it means for L'OPTION	Status
Personal data	Law 09-08 on the protection of individuals with regard to the processing of personal data; CNDP	Prior declaration of the processing (accounts, orders, delivery, location). Information notice and consent in the app; rights of access, rectification and objection; security measures	Not filed
Health-related data	Law 09-08 (sensitive data); CNDP prior authorization	Weight, height, activity, calorie estimates and health-app data are treated as sensitive: explicit consent and, as a rule, CNDP authorization; decide on a separate consent screen (DECISIONS #21)	Not filed
Transfer abroad	Law 09-08 rules on transfers; CNDP	Supabase hosts data in Ireland (eu-west-1); Expo push service and map providers (Apple, Google) operate abroad: check the CNDP adequacy list or request transfer authorization; list processors and countries in the policy	Not filed
Retention	Law 09-08 (limited duration)	Written retention periods for activity, meals, addresses, driver tracks, orders after account deletion (DECISIONS #14, #22)	Not decided
Consumer information	Law 31-08 on consumer protection	Clear prices in MAD incl. fees and taxes before ordering, terms of sale, order confirmation, complaints contact; rules for distance selling	Pricing not approved
Electronic contracts	Law 53-05 on the electronic exchange of legal data	Terms of use / sale accepted electronically; keep proof of acceptance	Terms not published
Food safety	Law 28-07 on food safety; ONSSA sanitary authorization or approval	Each company-owned kitchen (Kitchen A first) needs the ONSSA authorization/approval, hygiene and traceability; allergen and ingredient information where required	Owner to confirm
Company and tax	Commercial register (RC), tax identifier (IF), ICE, taxe professionnelle; DGI; TVA	ICE and legal mentions on invoices/receipts; TVA treatment of meals and delivery fees (H3); cash-on-delivery receipts and daily closing	Accountant to confirm
Drivers and staff	Labour Code, CNSS	Status of delivery drivers (employees or self-employed), insurance, CNSS affiliation; driver location data covered by the CNDP declaration	Owner to confirm
Local permits	Commune / municipal authorizations	Operating licence for each kitchen and any signage	Owner to confirm
Minors	Law 09-08 consent; store age ratings	Minimum age and whether minors may order or see calorie estimates (C7)	Not decided

7. Definition of "production ready"

L'OPTION can be called production ready only when all of the following are true and recorded in the evidence log:

#	Condition	Today
1	All credentials of section 2 required for the chosen launch scope are configured in their correct place, and none appears in git, the app bundle or logs (scan K3/B7 re-run on the release candidate).	Not met
2	Real Google, Apple and e-mail sign-in, password reset/verification and account deletion pass on an iPhone and an Android phone.	Not met
3	Pricing, fees and TVA are approved, trusted server-side order creation exists, and a full staging order lifecycle (order, kitchen, driver, cash collection) passes; only then is checkout enabled.	Not met
4	Phase 1C and V1 migrations are reviewed, rehearsed with rollback on staging, and applied to production with written owner approval and a backup.	Not met
5	All automated suites pass on the release commit: npm run check, every supabase/tests/run_*.sh, and the local e2e.	Not met
6	EAS production builds for iOS and Android succeed, and every device procedure (I, D, B, G series) passes with screenshots and dates.	Not met
7	Calorie-engine constants and MET values are approved in writing.	Not met
8	Privacy policy, terms, support contact and account-deletion web page are published; store privacy forms, foreground-service declaration and background-location justification are submitted.	Not met
9	CNDP declaration, health-data authorization and transfer authorization are filed (receipt numbers recorded); ONSSA, tax and company obligations are confirmed by the lawyer/accountant.	Not met
10	The owner approves the release in writing before any store submission (K14).	Not met

Current verdict (2026-11-05): not production ready. Code and automated tests are in good shape; the blockers are credentials, native builds, device tests, owner decisions (pricing, calorie constants, account deletion, Apple Health / Health Connect, Maps key) and the Moroccan legal filings.